



Executive summary

AI AGENT + MCP + SKILL SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.15.0

Incomplete scan - close the coverage gaps

The selected static scope was not fully inspected. There are 0 open findings, including 0 critical/high findings. Resolve reported gaps and review existing evidence before relying on this result.

0

OPEN FINDINGS

1

COVERAGE GAPS

9

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Incomplete selected scope.

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

No open finding groups. Review accepted exceptions, coverage limits and active controls before drawing a deployment conclusion.

[Record a review decision and rescan](#)

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: 2f01d3255747009bedad350dc442b07f55b99bf94f644dab0b00f536f50d76a4



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Metrics and calculation	4
Observed findings and mitigating layers	5
Optional advisory review and evidence	6
Coverage gaps and required validation	10
Control checklist and evidence requirements	11
Scan configuration and scope	12
Deterministic checks and optional review	15
Coverage, misses and validation by area	16
Appendix / Deterministic rule inventory	23
Interactive review workspace	24



Priorities and first actions

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		0
Medium		0
Low		0
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 0/0 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 2/2 answered checks. Proposals require verification.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Metrics and calculation

No defensible universal security percentage can be calculated from static patterns or model opinions. Zero findings and 100% answered checks do not mean secure or compliant.

Measure	Result	Interpretation
Open deterministic findings	0 (0 critical/high)	Observed pattern counts. No severity weights or compromise probabilities are assigned.
Partial deterministic mapping reach	100.00% (1/1)	Active selected controls with an active selected mapped rule. Available partial coverage, not a pass rate.
Optional AI answer coverage	100.00% (2/2)	Active selected checks with a model answer, including concerns and unknowns. Review completion, not safety.

Selected scope: 4 rules (4 active); 1 controls (1 active); 2 active acceptance checks. 1 recorded coverage gaps.

Exact formulas

$100 \times \text{active selected controls with at least one active selected mapped rule} / \text{active selected controls}$. This describes partial rule availability, not completed tests, passes, or control effectiveness.

$100 \times \text{unique active selected acceptance checks with a received, valid model answer} / \text{active selected acceptance checks}$. An answer can be a concern or an explicit unknown. Disabled AI has zero answered checks; an empty denominator is not applicable (null), never 100%.

Advisory AI outcomes

Check outcome	Count
supported_by_code	0
potential_gap	1
needs_runtime_validation	0
needs_human_review	0
insufficient_evidence	1
not_applicable_proposed	0
not_reviewed	0

Supported by code and proposed non-applicability are advisory interpretations. Runtime/human validation and missing evidence remain unresolved. AI cannot erase findings, lower their severity, change the severity gate, or turn checks into passes.

Justified and disabled rules/checks are excluded from active metric denominators without pass credit. Findings with user decisions or baseline suppressions remain visible outside open-finding counts. Selection narrows the requested scope; it does not establish the excluded system is safe.

The existing CLI gate uses open deterministic findings at or above the configured severity. Scan/review/export errors can make requested work incomplete. Coverage percentages and model opinions never dismiss the gate.



Observed findings and mitigating layers

No selected static pattern was emitted. Review coverage gaps and control evidence before drawing a conclusion.



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

Additional model concern - unverified

Review coverage is incomplete: the payload reports one coverage gap and `scan_complete_within_selected_scope=false`, with no source context. Zero reported findings does not establish security. The gap details and intended file inventory are needed to determine what remains unassessed.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Applicability is unestablished because no agent or MCP implementation evidence is supplied; uncovered files could contain relevant trust boundaries.

When this applies: Further review applies if the coverage gap affects files or configuration within the intended assessment scope.

1. Obtain the scanner's coverage-gap details, intended file inventory, and exclusion configuration before proposing code changes; no specific vulnerable API or incorrect setting is established.

2. Resolve applicable read or scope issues and repeat static analysis; arrange source review for relevant files unsupported by the scanner.

Verify: Compare the assessed file inventory against the intended scope and document every remaining exclusion or unsupported file.

Verify: Confirm whether relevant agent/MCP entry points were covered; assess runtime authorization and isolation separately if those components exist.

Bounded evidence investigation

Follow-up rounds: 2. Requests served / denied: 16 / 0. Captured files offered: 9. All requests share the configured call and evidence budgets; target tools and code are never executed.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:140-219 / risk_hypothesis / served

Reason: Trace path validation into filesystem access, including missing-path handling and writes, to assess whether attacker-controlled paths can change between validation and use.

Counterevidence: Seek access-time enforcement, safe handling of nonexistent targets, and filesystem operations bound to validated objects.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:220-299 / risk_hypothesis / served

Reason: Inspect the remainder of writing and the move operation for temporary-file placement, destination validation, overwrite behavior, and permissions.

Counterevidence: Seek exclusive creation, no-follow handling, destination revalidation, restrictive permissions, and cleanup on failure.

EXEC-04:1 / file-987db9b947eadc16acc4f7f9:7-86 / counterevidence / served

Reason: Inspect the complete containment decision underlying the supplied realpath check; normalization alone does not establish directory containment.

Counterevidence: Seek separator-aware containment, rejection of traversal and incompatible roots, and handling of absolute paths and platform differences.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:155-234 / boundary_context / served

Reason: Inspect the streaming helper and surrounding tool registration to connect client-supplied paths to actual reads despite incomplete static callback coverage.

Counterevidence: Seek mandatory validation before stream creation, constraints on tool arguments, and additional access-time guards.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:235-314 / boundary_context / served

Reason: Continue inspecting tool entrypoints for caller-side constraints and whether validated paths are consistently used by read operations.

Counterevidence: Seek validation on every supplied path, restrictions on batch access, and guards that prevent direct use of unvalidated arguments.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:725-786 / boundary_context / served

Reason: Inspect how MCP roots become allowed directories and how initialization or root changes affect the filesystem authorization boundary.

Counterevidence: Seek explicit policy intersection, rejection of invalid roots, and fail-closed behavior before initialization or after root-update failures.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:1-80 / boundary_context / served

Reason: Inspect storage and initialization of allowed directories and the beginning of relative-path resolution used by validation.

Counterevidence: Seek immutable or normalized policy state, rejection of empty or overbroad policies, and caller constraints on policy updates.

EXEC-04:2 / file-9b73cee629c530fd3bf63a92:1-43 / boundary_context / served

Reason: Identify declared test tooling and validation scripts to determine what test evidence is available for the required adversarial filesystem cases.

Counterevidence: Seek explicit filesystem security test configuration; script declarations alone cannot establish test coverage or successful execution.



EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:81-139 / counterevidence / served

Reason: Inspect relative-path resolution and the Unicode-equivalent fallback used for nonexistent targets, where containment of the final target remains unresolved.

Counterevidence: Seek canonical parent containment, rejection of existing symlink targets, and checks on the actual returned target rather than only the original spelling.

EXEC-04:1 / file-2f90dc06de04ee6c31f5153c:1-77 / boundary_context / served

Reason: Determine what validation occurs before client-supplied MCP roots replace the allowed-directory policy.

Counterevidence: Seek canonicalization, URI restrictions, directory validation, and intersection with an independently authorized server policy.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:315-394 / boundary_context / served

Reason: Continue the visible tool registrations to trace client-controlled arguments into batch reads and write operations despite incomplete callback parsing.

Counterevidence: Seek mandatory validation for every argument and access-time barriers or caller restrictions before filesystem operations.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:395-474 / boundary_context / served

Reason: Inspect subsequent mutation entrypoints to determine whether the write and editing helpers receive validated targets and additional restrictions.

Counterevidence: Seek validation of all source and destination arguments, authorization constraints, exclusive creation, or restrictions on concurrent filesystem changes.

EXEC-04:1 / file-5ae3d39aff74aeb01e9363af:635-714 / boundary_context / served

Reason: Inspect later tool registrations for callers of moveFile and other filesystem helpers; the visible destination existence check and rename are separate operations.

Counterevidence: Seek source and destination validation, no-replace semantics, serialization, or caller-side constraints that reduce overwrite and path-substitution concerns.

EXEC-04:1 / file-efb8eb6d32ff5732dfea3c05:300-379 / risk_hypothesis / served

Reason: Follow applyFileEdits through its eventual write and inspect adjacent operations for enforcement omitted from the current excerpts.

Counterevidence: Seek reuse of guarded writing, dry-run restrictions, canonical containment checks, and filesystem access bound to validated objects.

EXEC-04:1 / file-9e181b70de0137f101e66dc0:1-25 / counterevidence / served

Reason: Inspect the supplied deployment definition for containment or permission barriers relevant to filesystem races and secret-directory access.

Counterevidence: Seek an unprivileged runtime identity, restricted filesystem exposure, and permission constraints; distinguish image configuration from actual deployment guarantees.

EXEC-04:2 / file-1e37847deefaaf829c40c17d:1-14 / boundary_context / served

Reason: Determine whether the declared test configuration supplies any concrete coverage context for adversarial filesystem tests.

Counterevidence: Seek explicit security-test inclusion or exclusions; configuration alone cannot establish that the required cases exist or were executed.

EXEC-04 / Advisory check review: reviewed



Check 1 / potential_gap

Visible MCP handlers validate caller-supplied paths before filesystem operations, and `validatePath` checks both requested-path containment and resolved symlink targets. However, validation returns a pathname that subsequent operations resolve again. If an attacker can replace filesystem components between validation and access, these checks may not constrain the actual object accessed. Atomic replacement and exclusive initial creation provide useful protection, but do not establish protection against parent-directory substitution. Editing also writes a temporary file without explicit exclusive creation or restrictive permissions. These are unverified concerns whose impact depends on concurrent filesystem access, deployment permissions, and umask. Upload, download, and extraction coverage cannot be established from the excerpts.

Risk hypothesis: An attacker able to mutate filesystem components could redirect a pathname after validation but before access. A principal with directory access could also potentially observe replacement content under default temporary-file permissions.

Trust boundary: Client-controlled tool paths enter `validatePath`, which returns canonical strings consumed by filesystem helpers. The unresolved boundary is between checking a pathname and accessing the filesystem object currently named by it.

Counterevidence considered: The supplied code checks lexical containment and resolved symlink targets, validates visible tool arguments, checks resolved Unicode components, uses 'wx' for initial creation, and uses randomized temporary names and atomic rename for replacement. These reduce static traversal and leaf-target risks. A deployment preventing hostile namespace mutation could further limit exposure, but actual deployment constraints are unprovided.

Conclusion limits: No race or disclosure was executed or demonstrated. Filesystem permissions, umask, caller restrictions, and omitted helpers may change the assessment. The callback parse diagnostic remains unresolved; manually following supplied handlers does not establish complete endpoint coverage. Archive and transfer applicability remains unknown.

Model supplied this advisory interpretation.

Evidence `src-ac462823e545f33c8551058e / index.ts:374-375`

Quoted excerpt: `const validPath = await validatePath(args.path);
await writeFileContent(validPath, args.content);`

Evidence `src-d28872b02bc6a10fe16c62ab / lib.ts:163-168`

Quoted excerpt: `const realPath = await fs.realpath(absolute);
const normalizedReal = normalizePath(realPath);
if (!isPathWithinAllowedDirectories(normalizedReal, allowedDirectories)) {
 throw new Error('Access denied - symlink target outside allowed directories: ${realPath} not in ${allowedDirectories.join(', ')}');
}
return realPath;`

Evidence `src-8231e4d7134a6b2856684c44 / lib.ts:341-344`

Quoted excerpt: `const tempPath = `${filePath}.${randomBytes(16).toString('hex')}.tmp`;
try {
 await fs.writeFile(tempPath, modifiedContent, 'utf-8');
 await fs.rename(tempPath, filePath);
}`

Verification still required: In an authorized isolated environment, exercise leaf and ancestor replacement between validation and reads, writes, edits, directory creation, and moves; check the actual objects accessed.

Verification still required: Inspect temporary-file permissions throughout replacement, including restrictive original permissions and permission-restoration failures.

Verification still required: Review deployment identity, directory ownership, mounts, and whether another principal can modify allowed-directory ancestors.

Verification still required: Confirm who may authorize MCP roots, whether empty root updates revoke access, and whether secrets can fall within an authorized root.

Verification still required: Obtain the remaining tool implementations and any upload, download, or extraction handlers; resolve endpoint coverage separately from this review.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: MCP tool arguments cross from the client or agent into server-side filesystem access. Canonical pathname checks are useful barriers, but their effectiveness at access time depends on namespace stability and deployment isolation.

When this applies: Prioritize changes where another principal can mutate accessible filesystem components or observe temporary files. Establish the intended roots authority and runtime permission policy before changing those behaviors.

1. Retain requested-path and resolved-target containment checks. Where concurrent namespace mutation is possible, use filesystem operations anchored to trusted directory handles with platform-enforced containment, or isolate the server so unauthorized principals cannot replace ancestors.
2. Create temporary files exclusively with restrictive initial permissions, such as `fs.open` with 'wx' and mode `0o600`, then write and apply the intended permissions through the same `FileHandle` before publication. Ancestor containment still requires a separate barrier.
3. Review `moveFile`'s separate existence check and rename against its no-overwrite contract; use an appropriate atomic no-replace operation or an explicitly enforced concurrency restriction where necessary.
4. Document the authority of client-provided roots. If clients must not expand server authorization, intersect requested roots with an independently configured server policy.



Verify: Retain regression evidence showing permitted operations work and unauthorized objects remain inaccessible during controlled filesystem substitutions.

Verify: Confirm temporary files never expose content more broadly than the approved permission policy, including failure cases.

Verify: Record deployment constraints and roots authorization decisions alongside adversarial test results.

Check 2 / insufficient_evidence

The supplied configuration establishes a Vitest test environment and coverage provider, but includes no test bodies or execution results demonstrating symlink races, archive traversal, absolute-path handling, overwrite attempts, or secret-directory reads. Existing path guards identify useful test targets but do not demonstrate testing. Missing test evidence does not establish that these tests are absent.

Risk hypothesis: Filesystem boundary regressions could remain undetected if tests cover only normalization or static symlinks and omit concurrent replacement, forbidden overwrites, or unauthorized content reads.

Trust boundary: The required evidence concerns adversarial validation of MCP filesystem access and any archive processing, from supplied arguments through observable filesystem effects.

Counterevidence considered: Vitest configuration and coverage instrumentation show a testing mechanism is configured. Existing security tests elsewhere are a plausible alternative, but no test bodies or results were supplied. Visible implementation guards do not establish test coverage.

Conclusion limits: Test existence, completeness, and outcomes cannot be determined. No runtime validation occurred. Archive functionality is unresolved, and incomplete callback parsing further limits confidence in the tested-surface inventory.

Model supplied this advisory interpretation.

Evidence src-c39da0c47ebf2e1715125cde / vitest.config.ts:5-6

Quoted excerpt: globals: true,
environment: 'node',

Evidence src-c39da0c47ebf2e1715125cde / vitest.config.ts:9-9

Quoted excerpt: provider: 'v8',

Verification still required: Obtain security test bodies and recent authorized execution results mapped to every requested scenario and supported platform.

Verification still required: Verify that race tests coordinate changes between validation and access, rather than testing only pre-existing symlinks.

Verification still required: Review absolute-path, traversal, overwrite, and secret-read assertions for checks on actual filesystem effects and returned content.

Verification still required: Identify any archive extraction surface and its tests, or obtain an owner-confirmed applicability assessment supported by complete surface coverage.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Tests must exercise the MCP argument-to-filesystem boundary and any roots-policy changes, since helper tests alone may miss endpoint-specific behavior.

When this applies: First obtain existing tests and results. Add missing cases only after comparing their coverage with the acceptance check; archive testing depends on whether extraction is exposed directly or indirectly.

1. Map existing tests to symlink races, traversal, absolute paths, overwrite attempts, and secret-directory reads, including end-to-end MCP calls.
2. Where missing, add coordinated leaf and ancestor substitution tests covering reads, edits, writes, directory creation, and moves.
3. Distinguish authorized write_file replacement from forbidden move_file destination replacement, including concurrent destination creation.
4. Use synthetic secret fixtures outside authorized roots and verify that no contents are returned or modified; include roots expansion and revocation scenarios.
5. For any extraction surface, cover traversal entries, absolute entries, link entries, destination overwrites, and temporary-file permissions.

Verify: Have the owner review test assertions and retain execution results tied to the reviewed revision and deployment platform.

Verify: Confirm tests inspect resulting objects, contents, and permissions rather than relying only on error messages or coverage percentages.

Verify: Record unresolved platform behavior and any human-confirmed archive applicability decision.



Coverage gaps and required validation

```
{"error": "MCP registerTool callback uses complex/default/rest parameters; tool endpoint coverage is incomplete", "kind": "parse_error", "path": "index.ts"}
```



Control checklist and evidence requirements

EXEC-04 / Constrain file and archive access

Scanner status: no_pattern_detected | validation: hybrid

1. Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Record review for EXEC-04:1

2. Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Record review for EXEC-04:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000
Requested scan ids	EXEC-04
Selected control ids	EXEC-04
Selected rule ids	AI015, AI016, AI037, AI047



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	1
Optional review / Analyst limits / Investigation rounds	2
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	3
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	900.0
Optional review / Cli login	never
Optional review / Cli timeout seconds	300.0
Optional review / Effective transport / Max request bytes	524288
Optional review / Effective transport / Max response bytes	1048576
Optional review / Effective transport / Model	gpt-6-astra
Optional review / Effective transport / Provider	codex_cli
Optional review / Effective transport / Timeout seconds	300.0
Optional review / Effective transport / Token optimizer	headroom
Optional review / Enabled	Yes
Optional review / Findings limit	100
Optional review / Include finding source	No
Optional review / Mode	full
Optional review / Provider	codex_cli
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No



Setting	Configured value
Review inputs / Review config	No
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	525747fc453830a4bc93b887c21161ff44c21212af1a525bbd5a9d615086954b
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.15.0



Deterministic checks and optional review

4 selected deterministic rules (4 active)

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	completed; 0 selected; 0 outside cap
Control review	completed; 1/1 active controls answered
Unanswered acceptance checks	0/2 requested checks
Control requests	3/3 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		1
Controls without rule mapping		0

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks propagate selected registered-tool inputs and same-file arguments/returns, retain aliases and exact literal constraints, and check selected execution/file/network sinks. JavaScript tokens support narrow registerTool callbacks and direct-return named/arrow wrappers. Explicit world-writable chmod modes are checked.

Optional analyst: A model can form a trust-boundary hypothesis, request bounded captured source ranges to inspect callers or guards, seek counterevidence and explain what the supplied code still cannot establish.

Can miss or misclassify: Cross-file flows, unknown decorators/methods, complex JavaScript wrappers, dynamic imports, reflection, generated code and runtime values can hide a risk. Recognized resource/binding failures remain gaps. A dangerous API can be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Skills and malicious-tool indicators

Deterministic: Bounded skill/tool/schema descriptions are checked for instruction hijacking, sensitive-data transfer, covert or approval-bypassing actions. Selected Spanish/French/German overrides and paired authority claims supplement English predicates. Python read-only tool annotations are compared with recognized direct write witnesses.

Optional analyst: A model can review intent, indirect social engineering, skill reference context and tool behavior visible in retrieved evidence, including cases where syntax or supported patterns are inconclusive.

Can miss or misclassify: A pattern is risk evidence, not proof of malicious authorship. Obfuscation, remote references, external packages, omitted context and runtime behavior can evade either layer.

Validate elsewhere: Inspect publisher provenance and the exact installed skill/tool; test consequential actions in an authorized isolated environment and verify effective permissions.



Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional request payload optimization

Request	Requested / actual engine	Outcome	Evidence payload bytes
Finding request	headroom / headroom	optimized	1229 -> 1185 44 bytes saved
Control request 1	headroom / headroom	optimized	9025 -> 8689 336 bytes saved
Control request 2	headroom / headroom	optimized	38903 -> 38174 729 bytes saved
Control request 3	headroom / headroom	optimized	59989 -> 59124 865 bytes saved

These are measured evidence-JSON bytes, excluding instructions, response schemas and provider wrappers. Token and cost savings were not measured. Evidence-preserving formatting does not validate the model's interpretation.



Optional-review audit details

Recorded field	Recorded value
Analyst / Check status counts / Insufficient evidence	1
Analyst / Check status counts / Potential gap	1
Analyst / Coverage / Attempted controls	1
Analyst / Coverage / Batch size	1
Analyst / Coverage / Call budget	3
Analyst / Coverage / Calls made	3
Analyst / Coverage / Catalog checks	2
Analyst / Coverage / Catalog controls	1
Analyst / Coverage / Disabled checks	0
Analyst / Coverage / Disabled controls	0
Analyst / Coverage / Evidence / Budget exhausted	max_candidates_per_control
Analyst / Coverage / Evidence / Bytes charged	58024
Analyst / Coverage / Evidence / Bytes read	58024
Analyst / Coverage / Evidence / Candidate rankings dropped	59
Analyst / Coverage / Evidence / Candidate snippets	123
Analyst / Coverage / Evidence / Characters selected	1993
Analyst / Coverage / Evidence / Controls total	1
Analyst / Coverage / Evidence / Controls with evidence	1
Analyst / Coverage / Evidence / Controls without evidence	None
Analyst / Coverage / Evidence / Evidence files	3
Analyst / Coverage / Evidence / Failed read bytes charged	0
Analyst / Coverage / Evidence / File read attempts	9
Analyst / Coverage / Evidence / Files read	9
Analyst / Coverage / Evidence / Files verified	9



Recorded field	Recorded value
Analyst / Coverage / Evidence / Full repository review	No
Analyst / Coverage / Evidence / Limitations	Keyword-selected excerpts are partial context and do not prove implementation, absence, effectiveness, or compliance., Only unchanged manifest files are eligible; scanner exclusions and unsupported files remain outside this review., Credentials and environment files are excluded; other redaction is best-effort and source can contain sensitive data., Read budgets reserve one sentinel byte and conservatively charge failed read attempts, even if failure happened before any source bytes were read., No target code is executed, imported, installed, or contacted; repository instructions cannot change retrieval., Runtime behavior and missing evidence require additional validation; an empty control mapping is not a pass.
Analyst / Coverage / Evidence / Limits / Max bytes	2000000
Analyst / Coverage / Evidence / Limits / Max candidates per control	64
Analyst / Coverage / Evidence / Limits / Max chars	60000
Analyst / Coverage / Evidence / Limits / Max chars per excerpt	2000
Analyst / Coverage / Evidence / Limits / Max excerpts per control	4
Analyst / Coverage / Evidence / Limits / Max file bytes	1000000
Analyst / Coverage / Evidence / Limits / Max files	200
Analyst / Coverage / Evidence / Limits / Max lines per excerpt	12
Analyst / Coverage / Evidence / Limits / Max snippets	240
Analyst / Coverage / Evidence / Manifest files	9
Analyst / Coverage / Evidence / Requested characters selected	38723
Analyst / Coverage / Evidence / Scope	bounded_excerpts_from_unchanged_scanner_manifest_files
Analyst / Coverage / Evidence / Selection method	deterministic_control_keywords_and_findings
Analyst / Coverage / Evidence / Skipped files	None
Analyst / Coverage / Evidence / Snippets selected	4
Analyst / Coverage / Excluded checks	0
Analyst / Coverage / Excluded controls	0
Analyst / Coverage / Justified checks	0
Analyst / Coverage / Justified controls	0



Recorded field	Recorded value
Analyst / Coverage / Omitted checks	0
Analyst / Coverage / Reviewed controls	1
Analyst / Coverage / Time budget seconds	900.0
Analyst / Coverage / Total checks	2
Analyst / Coverage / Total controls	1
Analyst / Coverage / Unreviewed control ids	None
Analyst / Coverage / Validated controls	0
Analyst / Enabled	Yes
Analyst / Errors	None
Analyst / Status	completed
Judge / Cli / Arguments	-a, never, exec, --ignore-user-config, --ignore-rules, --ephemeral, --skip-git-repo-check, --sandbox, read-only, --json, --color, never, --disable, shell_tool, --disable, unified_exec, --disable, code_mode, --disable, code_mode_host, --disable, computer_use, --disable, browser_use, --disable, browser_use_external, --disable, browser_use_full_cdp_access, --disable, in_app_browser, --disable, image_generation, --disable, view_image, --disable, artifact, --disable, apps, --disable, plugins, --disable, plugin_sharing, --disable, hooks, --disable, multi_agent, --disable, multi_agent_v2, --disable, skill_search, --disable, workspace_dependencies, --disable, shell_snapshot, --disable, memories, --disable, sleep_tool, --disable, goals, --disable, remote_plugin, --disable, tool_suggest, -c, web_search="disabled", -c, mcp_servers={}, -c, project_doc_max_bytes=0, -c, skills.include_instructions=false, -c, model_reasoning_effort="high", --output-schema, <private temporary directory>/response-schema.json, --model, gpt-6-astra, -
Judge / Cli / Auth mode	cli_managed
Judge / Cli / Cli version	0.154.0
Judge / Cli / Descendant termination	process_group
Judge / Cli / Executable	codex
Judge / Cli / Isolation	CLI capability restrictions; installed executable and administrator policy remain trusted
Judge / Cli / Provider	codex_cli
Judge / Cli / Repository working directory	No
Judge / Cli / Request bytes	3399
Judge / Cli / Request sha256	1cbfb6fb95ad2a2c18d67e524b2eb46ca2f811b54bd97f39a0d5b210b9386f28
Judge / Cli / Requested model	gpt-6-astra
Judge / Cli / Response bytes	1942



Recorded field	Recorded value
Judge / Cli / Response sha256	b3c712bdfbae0184ebd289861f2c6decef2240688790843d0f99d465b9bbb50e
Judge / Cli / Stage	findings
Judge / Cli / Startup warnings	codex_code_mode_intentionally_disabled
Judge / Cli / Structured output requested	Yes
Judge / Cli / Token budget enforced	No
Judge / Cli / Token optimization / Bytes saved	44
Judge / Cli / Token optimization / Engine	headroom
Judge / Cli / Token optimization / Evidence preserved	Yes
Judge / Cli / Token optimization / Fallback reason	Not configured
Judge / Cli / Token optimization / Headroom version	0.37.0
Judge / Cli / Token optimization / Original payload sha256	adcdb02f28a0cd3b6a65004baeda9aa3717c8a3193f0aff9de94684df692a9fb
Judge / Cli / Token optimization / Payload bytes after	1185
Judge / Cli / Token optimization / Payload bytes before	1229
Judge / Cli / Token optimization / Requested	headroom
Judge / Cli / Token optimization / Schema version	1.0
Judge / Cli / Token optimization / Scope	Evidence JSON only; excludes instructions, response schemas and provider wrappers
Judge / Cli / Token optimization / Sent payload sha256	e098314e436eef915ee8b3fbd72426d928cb19c372e24aad98cccc84b3dbcbe0
Judge / Cli / Token optimization / Status	optimized
Judge / Cli / Token optimization / Token savings measured	No
Judge / Cli / Tools policy	disabled_for_advisory_review
Judge / Cli / Transport	official_cli
Judge / Enabled	Yes
Judge / Model	gpt-6-astra
Judge / Omitted open findings	0
Judge / Provider	codex_cli



Recorded field	Recorded value
Judge / Selected findings	0
Judge / Source context requested	No
Judge / Source context sent count	0
Judge / Source context skipped	None
Judge / Status	completed



Appendix / Deterministic rule inventory

Only selected rules appear here. User-justified and disabled selections remain recorded in the decision audit and do not earn pass credit.

AI015 / Externally influenced filesystem path

A filesystem operation consumes an obvious external-input expression. Review whether canonical path checks and symlink handling confine access to the intended workspace.

AI016 / Race-prone temporary filename creation

`tempfile.mktemp` returns an unused name without atomically creating the file, allowing a race with another local process.

AI037 / Archive extraction without an explicit safe filter

A tar extraction call has no explicit safe data filter, or selects a fully trusted filter. Behavior depends on the Python version and archive provenance.

AI047 / Filesystem permissions explicitly allow writes by everyone

A recognized Python `chmod` call sets the other-write permission bit. Shared agent workspaces, tool artifacts or credential files may be changed by another local identity. Actual access depends on platform permissions, ownership, ACLs and deployment isolation.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Acceptance check review

[Back to evidence](#)

EXEC-04:1 Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Evidence binding: 991cdd9638c7520e68e6515db8b9f559ef0da6cc8be650ce4ecd0ab0b1e5f890

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-04:2 Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence binding: 8345dc45e9b1f075a7c19bb286c4cafc06589fc8a32123064a9baac2275ed136

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Coverage gap review

[Back to evidence](#)

index.ts: MCP registerTool callback uses complex/default/rest parameters; tool endpoint coverage is incomplete

Evidence binding: e0ae5be75e42f42bb54d5a88dd207659071285681196200431ee47a98a59acf7

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE